

Secure coding practices

[Source: Page 451, CISSP for Dummies]

The purpose of secure coding practices is the reduction of exploitable vulnerabilities in tools, utilities, and applications. The practice of secure coding isn't just about secure coding, but many other considerations and activities. Here are some of the factors related to secure coding:

Tools.

From the selection and configuration of integrated development environments, to the use of static and dynamic code testing tools (SAST and DAST, respectively), tools can be used to detect the presence of source code defects including security vulnerabilities. The earlier such defects are found, the less effort it takes to correct them.

Processes.

Software development processes need to be designed and managed with security in mind. Processes define the sequence of events; in the context of software and systems development, security-related steps such as peer reviews and the use of vulnerability scanning tools will ensure that all the right steps are taken to make sure that source code is reasonably free of defects.

Training.

Software developers and engineers are more likely to write good, safe code when they know how to. Training in secure development is essential. Very few universities include secure development in their undergraduate computer science programs. Secure coding is not a part of university training, so organizations must fill the gap.

Incentives.

Money talks. Providing incentives of some form will help software developers pay more attention to whether they're producing code with security vulnerabilities. Perhaps rewards for the fewest defects per calendar quarter or year is a good start.

Selection of source code languages.

The selection of source code languages and policies about the use of open-source code comes into play. Some coding languages by design are more secure (or we might say "safe") than others. For example, the C language, as powerful as it is, has no protective features, which requires software developers to be more skilled and knowledgeable about writing safe and secure code. Developed in the 1970s, the C language was created during an era when there was more trust. The point is, some languages are, by design, safer than others.